CS 591 Lab Notebook

Lab 4

Name: Jarren Calizo
OdinID: calizo
Date: May 4, 2025

Table of Contents

1. *Lab Overview* 2

2. *Lab 4.1 Authentication*
    - Step 1: TryHackMe Hydra Credential Spraying (Web Form + SSH) 3
    - Step 2: Have I Been Pwned Analysis 4
    - Step 3–5: Social Engineering Toolkit (SET) – Credential Harvesting via Phishing 6
    - Steps 6–7: Cloning oregonctf.org and Harvesting Credentials with SET 9

3. *Lab 4.2 Phishing and Social Engineering*
    - Step 1: Phishing Scams 11
    - Step 2: Phishing Training 14
    - Step 3: TryHackMe Phishing – Room Completion and Walkthrough 15

Lab Overview

In Lab 4, we explored the foundational mechanics and threats surrounding authentication and phishing through a combination of offensive security simulations, real-world breach analysis, and social engineering techniques. This lab was broken into two parts: Lab 4.1: Authentication and Lab 4.2: Phishing and Social Engineering, each reinforcing critical security concepts with practical walkthroughs and real threat data.

Lab 4.1 began by examining the credential spraying process using Hydra on both HTTP login forms and SSH services. Through the TryHackMe Hydra room, I performed brute-force dictionary attacks against known user accounts, highlighting how weak or reused passwords can compromise authentication systems with minimal effort. This transitioned into analyzing breach exposure using HaveIBeenPwned, where I learned how widely-used passwords like “123456” have appeared in over 127 million breaches. These exercises drove home the value of unique credentials and the systemic risk posed by poor password hygiene.

The next portion of Lab 4.1 used the Social Engineering Toolkit (SET) to simulate phishing attacks from an attacker’s perspective. I cloned a Google login page and a university CTF portal, then harvested credentials through spoofed websites hosted on a Kali VM. Seeing stolen credentials appear in real-time on the console after just one click provided strong evidence of how deceptively simple phishing infrastructure can be deployed—especially when social trust and interface mimicry are weaponized.

Lab 4.2 then pivoted to a defensive lens. I analyzed several real phishing scams from Reddit, Berkeley’s Phish Tank, and Cofense to understand how adversaries exploit trust, urgency, and data collection triggers. I followed up by completing the Department of Defense’s Phishing Awareness Training to formally solidify my grasp of phishing tactics and mitigation strategies. Finally, I completed two in-depth TryHackMe rooms covering phishing email anatomy, attachment payloads, credential harvesting workflows, and redirection traps hidden in HTML. Hands-on decoding of malicious attachments and defanging suspicious URLs helped me internalize how to respond to phishing threats with both speed and caution.

Altogether, this lab emphasized both the offensive mindset needed to simulate and understand credential abuse and the defensive awareness required to detect and respond to phishing campaigns in real-world environments.

Lab 4.1 Authentication

Step 1: TryHackMe Hydra Credential Spraying (Web Form + SSH)

To begin this authentication lab, I completed the Hydra TryHackMe room, which walks through brute-force credential spraying using the Hydra tool. This exercise emphasized both web-based login form attacks and SSH-based login attempts using known usernames and password lists, illustrating real-world password security concerns.

After launching the AttackBox and deploying the vulnerable machine at http://10.10.253.250, I targeted the exposed login portal first. By inspecting the page's POST request structure and error message content, I confirmed the login form used username and password fields, and responded with the string "Your username or password is incorrect" upon failed attempts.

I ran the following Hydra command to perform the web-based brute-force attack on user molly using the rockyou.txt wordlist:

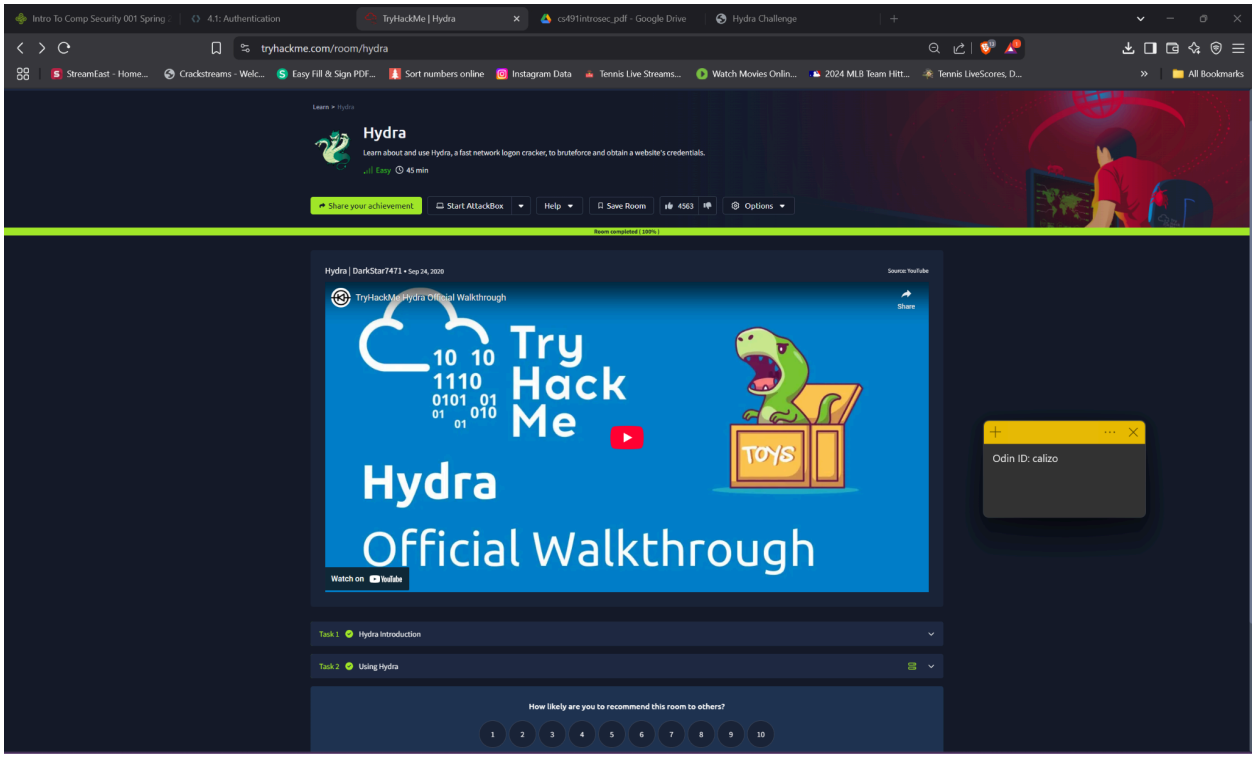
- hydra -l molly -P /usr/share/wordlists/rockyou.txt 10.10.253.250 http-post-form "/login:username=^USER^&password=^PASS^:Your username or password is incorrect" -V

Once Hydra identified the correct password, I used it to log in and retrieve Flag 1.

Next, I pivoted to attacking SSH on the same host using a similar dictionary approach:

- hydra -l molly -P /usr/share/wordlists/rockyou.txt 10.10.253.250 ssh

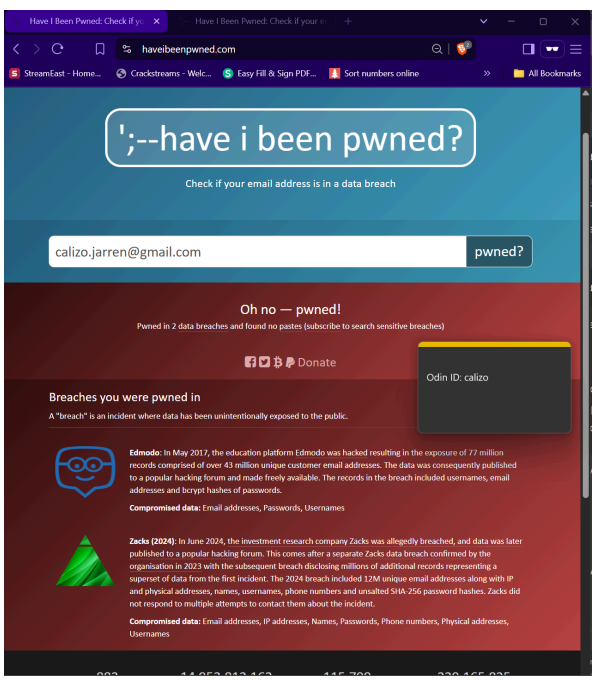
Hydra successfully cracked the SSH credentials for molly, allowing me to connect via SSH and extract Flag 2, completing the full lab sequence. The TryHackMe room now shows as 100% complete.

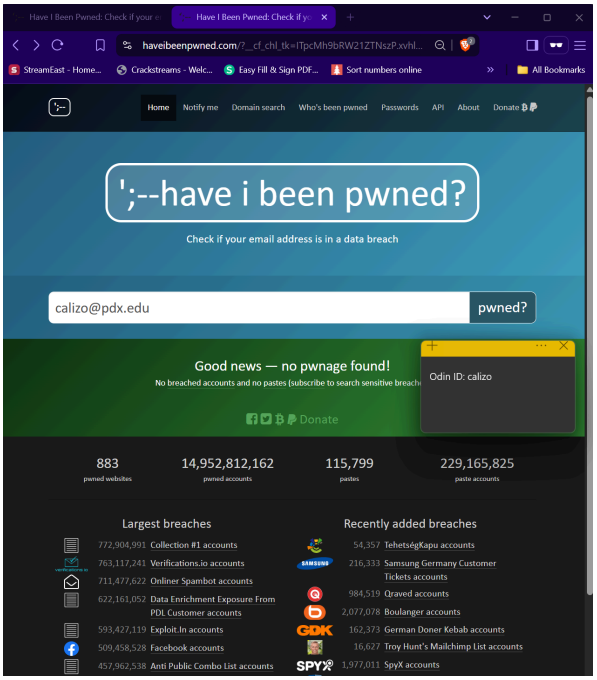


This step reinforced the mechanics of credential spraying across multiple protocols and the need for hardened authentication practices — particularly against dictionary-based attacks using weak or default passwords.

Step 2: Have I Been Pwned Analysis

To explore the real-world consequences of password reuse and data breaches, I visited HaveIBeenPwned.com to check whether either my academic or personal email addresses have been involved in any known data breaches. My Portland State University email address (calizo@pdx.edu) showed no record of compromise, indicating that it has not appeared in any public breach databases.





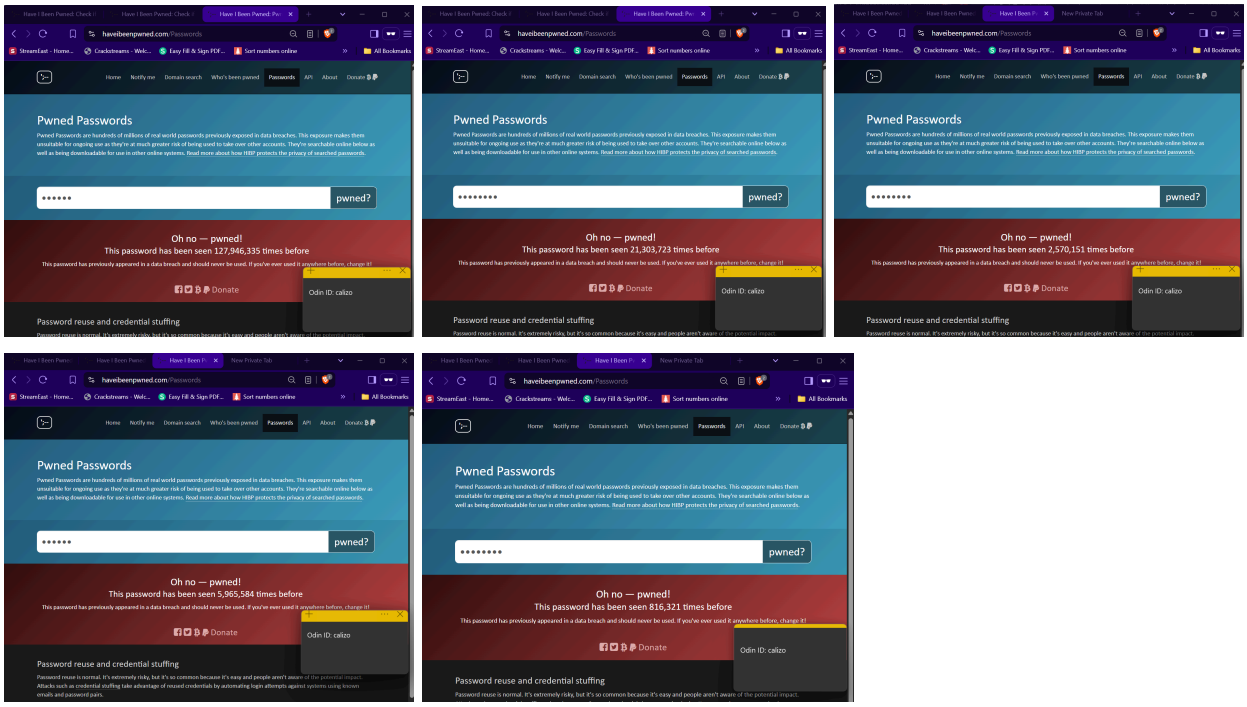
In contrast, my personal Gmail address (calizo.jarren@gmail.com) has been found in two breaches:

- Edmodo (2017): This educational platform was compromised, leaking over 77 million records. Exposed data included email addresses, bcrypt-hashed passwords, and usernames.
- Zacks (2024): A significant breach involving the financial research platform Zacks exposed over 12 million user records. The data compromised in this incident included email addresses, IP addresses, full names, usernames, phone numbers, physical addresses, and salted SHA-256 password hashes.

This reinforces the critical importance of using unique, strong passwords for each service, especially given the broad scope of exposed personally identifiable information (PII) in these breaches.

To further emphasize password hygiene risks, I visited HaveIBeenPwned's Password Search Tool and queried the following five commonly used passwords:

Password	Times Seen in Breaches
123456	127,946,335 times (most common)
password	21,303,723 times
iloveyou	2,570,151 times
abc123	5,965,584 times
princess	816,321 times



The most frequently breached password among the list was clearly 123456, having appeared in over 127 million breaches, making it one of the most insecure choices someone could use.

This exercise serves as a stark reminder that credential stuffing attacks thrive on weak and reused passwords. Strong password management practices—such as using password managers and multi-factor authentication—should be the norm, not the exception.

Step 3-5: Social Engineering Toolkit (SET) - Credential Harvesting via Phishing

To simulate a credential harvesting attack from the perspective of an adversary, I utilized the Social Engineering Toolkit (SET), a Python-driven suite bundled with Kali Linux designed for exploiting the human element. The goal was to craft a believable Google phishing page and verify credential capture behavior when a victim submits login information.

Step 3 - Launching SET and Selecting Web Templates

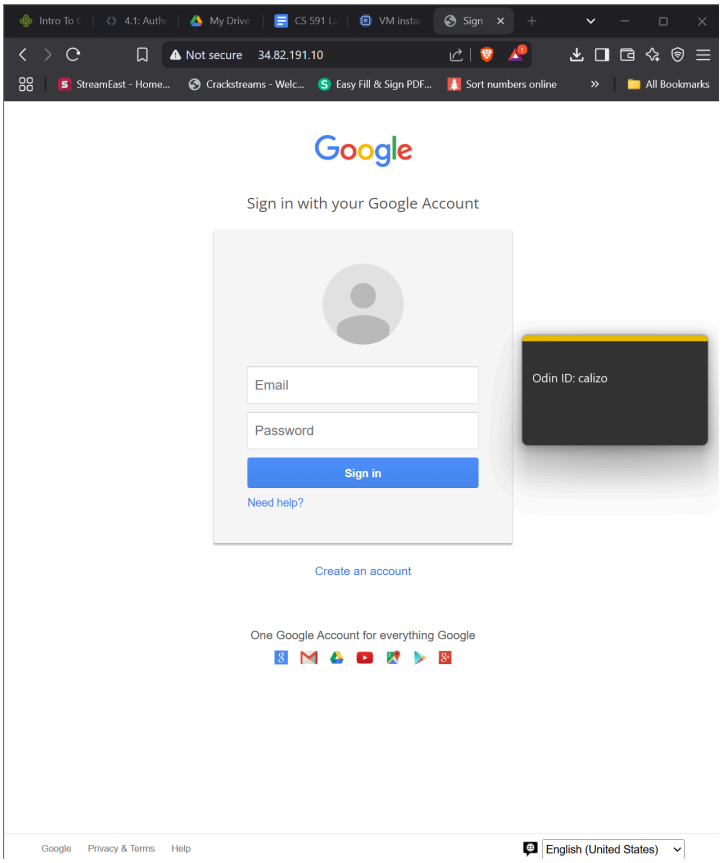
After initializing my Kali VM, I ran sudo setoolkit to open the SET CLI. Navigating through the menus, I selected:

- 1) Social-Engineering Attacks
- 2) Website Attack Vectors

- 3) Credential Harvester Attack Method
- 1) Web Templates

When prompted for the IP address to use for credential POST-back (i.e., where stolen credentials are sent), I entered the external IP of my Kali VM instance: 34.82.191.10 — ensuring port 80 (HTTP) was allowed through GCP's firewall.

Step 4 - Google Phishing Lure Setup
From the Web Templates list, I chose option 2 for Google, which triggered the cloning process for Google’s login interface. The SET server then spun up a hosted version of the spoofed Google login page on my VM's IP. I verified the fake site by visiting http://34.82.191.10 in the browser, which mimicked Google's login prompt convincingly.

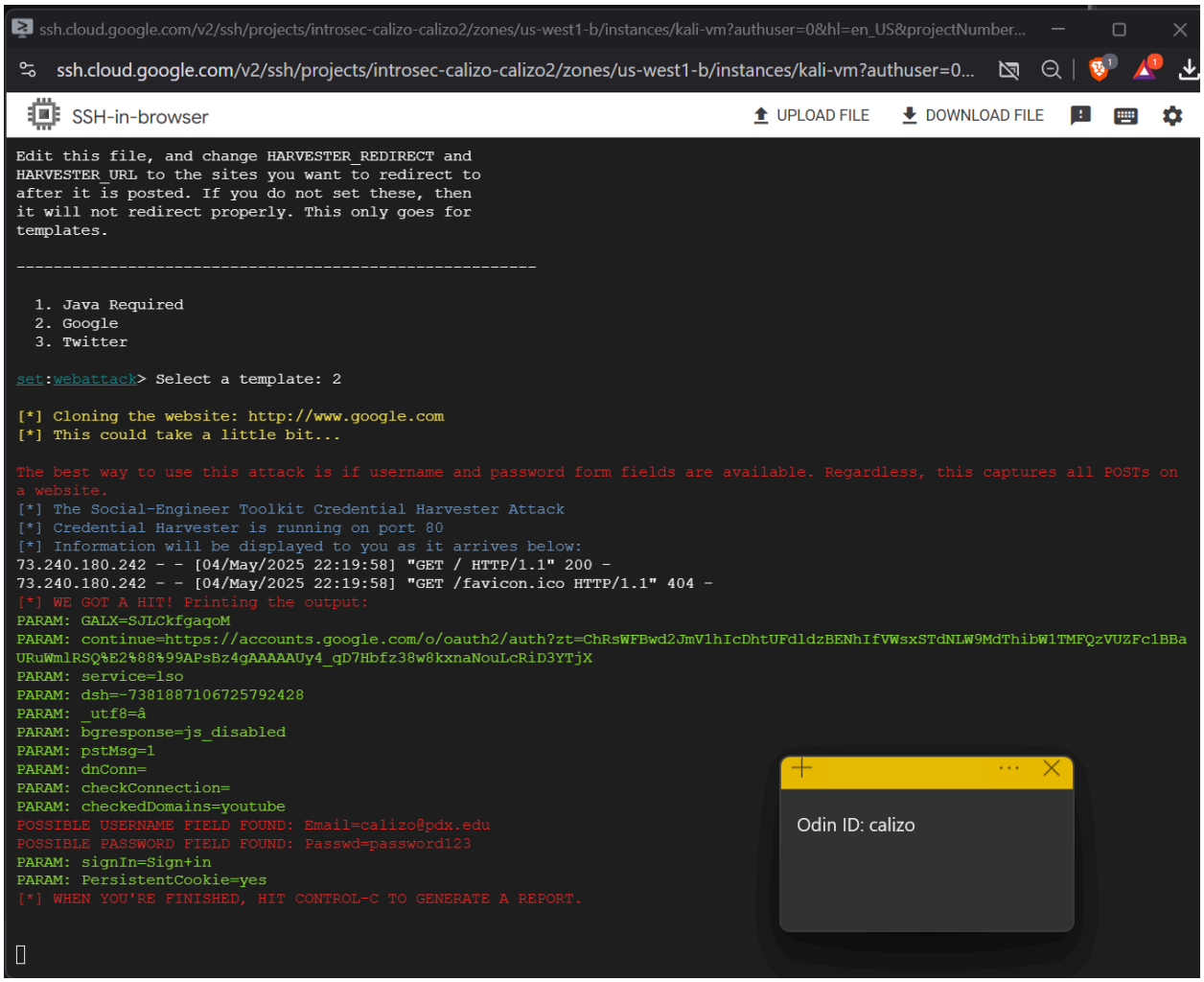


This type of lure is incredibly dangerous when combined with realistic phishing messages like “Click here to review a Google Doc,” as the user is redirected to a convincing clone site — with their credentials harvested in the background.

Step 5 - Credential Collection Demonstration
To simulate a phishing victim, I submitted a bogus login using my @pdx.edu email and

a test password (password123). Upon submission, the spoofed page redirected to the legitimate Google homepage, while the SET console captured the credentials in real-time. The output logs confirmed successful harvesting:

- Email=calizo@pdx.edu
- Passwd=password123



Once confirmed, I hit Ctrl+C to terminate the phishing server and exited SET completely, cleaning up the running services before moving to the next steps.

This exercise served as a sobering reminder of how easy it is to deploy convincing phishing attacks using freely available tools. It also reinforced the importance of phishing awareness training and the need for modern defenses such as 2FA, domain whitelisting, and browser-integrated anti-phishing protections. Had I been a real victim, my university credentials would have been fully compromised in less than a minute.

Steps 6-7: Cloning oregonctf.org and Harvesting Credentials with SET

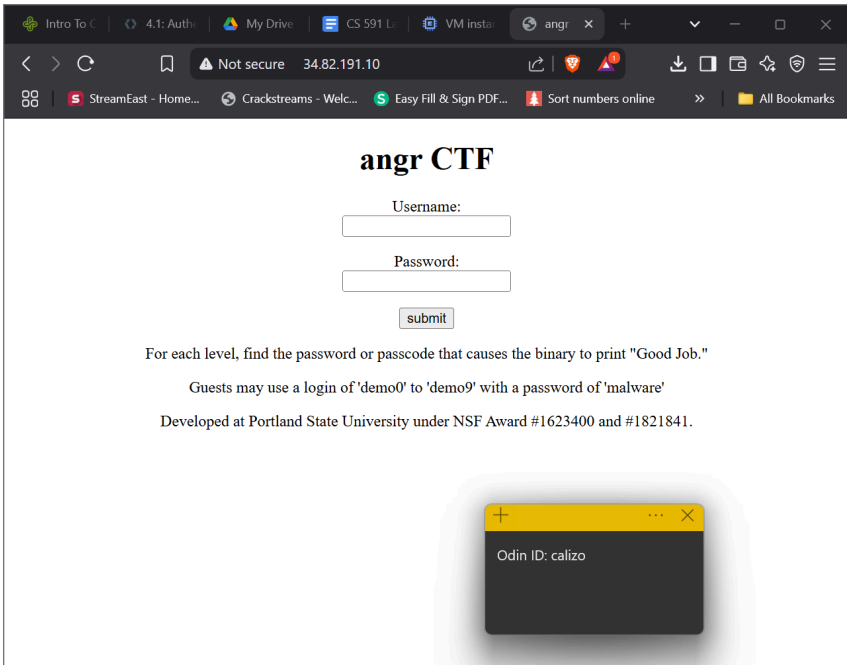
In the final section of Lab 4.1, we transitioned from using pre-configured phishing templates to cloning arbitrary targets. Specifically, we leveraged the Social Engineering Toolkit (SET) to replicate the https://cs201.oregonctf.org site and simulate credential harvesting against an academic CTF portal.

Step 6 - Site Cloner Setup (Manual Recon)
After restarting setoolkit using sudo setoolkit, I navigated to:

- 1) Social-Engineering Attacks → 2) Website Attack Vectors → 3) Credential Harvester Attack Method → 2) Site Cloner

When prompted, I entered my Kali VM's external IP address, 34.82.191.10, for the POST back location. I then cloned the CS201 CTF site by providing the URL https://cs201.oregonctf.org. SET began cloning and initialized a listener on port 80, preparing to intercept form submissions.

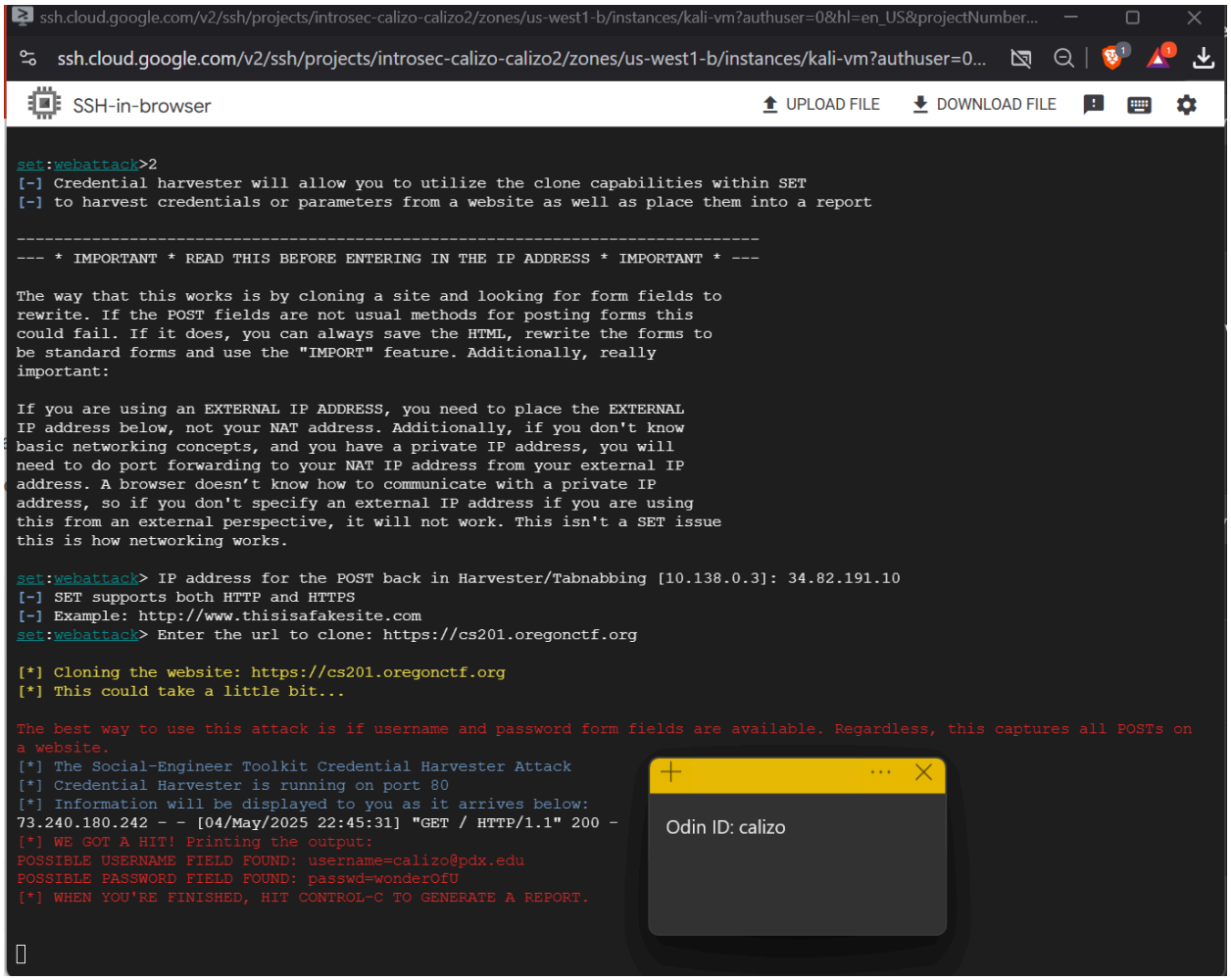
Screenshot reference: The hosted site visibly replicated the angr CTF login page (http://34.82.191.10), complete with input fields for "Username" and "Password."



Step 7 - Credential Harvesting (Manual Test & Verification)
To simulate a phishing victim, I accessed the fake site via browser and submitted fake credentials:

- Email: calizo@pdx.edu
- Password: wonderOfU

SET's terminal window confirmed the data capture immediately after submission:
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=calizo@pdx.edu
POSSIBLE PASSWORD FIELD FOUND: password=wonderOfU

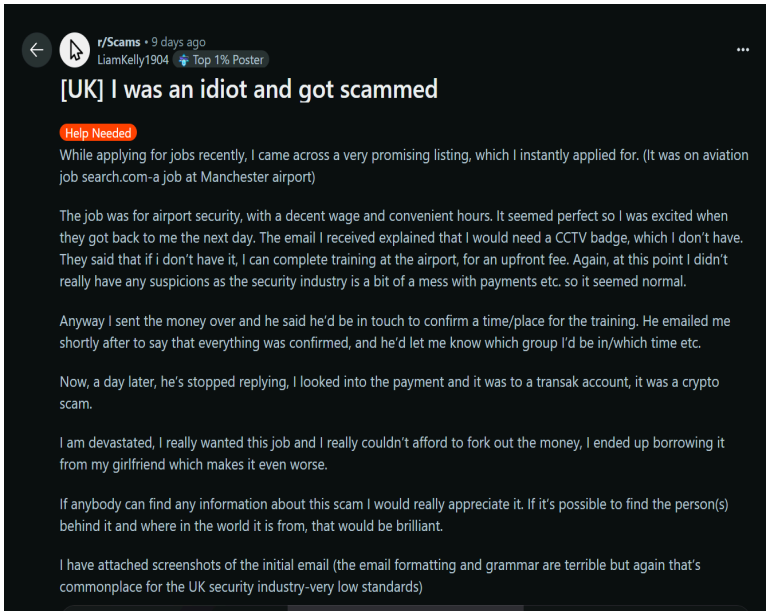


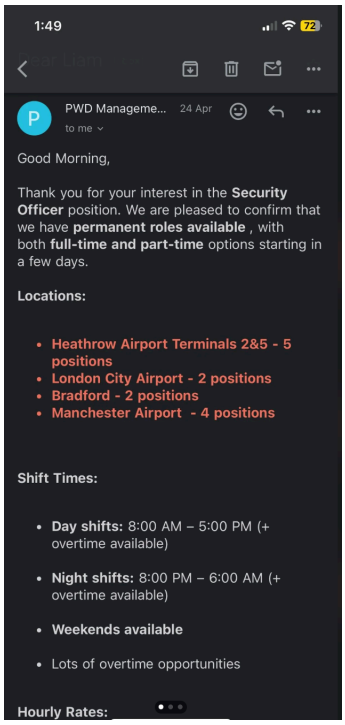
This step reinforced how easy it is for attackers to clone a legitimate site and deceive users with lookalike login pages—especially when HTTPS is not properly enforced or domain spoofing protections aren’t in place.

Lab 4.2 Phishing and Social Engineering

Step 1: Phishing Scams

Example 1: Fake Job Recruitment - r/Scams [UK] Airport Security Post





https://www.reddit.com/r/Scams/comments/1k7krw6/uk_i_was_an_idiot_and_got_scammed/

Analysis:

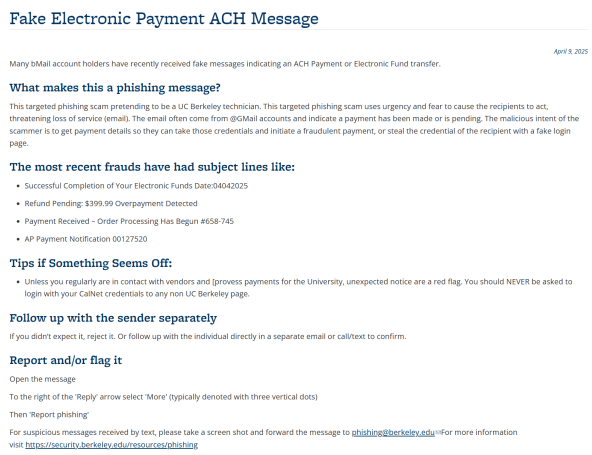
- Trust: The scammer impersonates a legitimate job recruitment agency using professional language, referencing known airports (Manchester, Heathrow), and offering what appears to be an official CCTV certification process.
- Urgency/Fear: The requirement to pay an upfront training fee creates financial urgency. The sense that job slots are filling fast pushes the victim into fast decision-making.
- Data Collection/Action: The attacker extracts upfront payment under the pretense of training fees, simulating common UK security job practices.

Phishing Tells & How to Detect It:

- Lack of verifiable business contact information.
- Use of crypto payment methods (Transak) for training—a red flag for impersonation scams.
- Generic language despite the claim of a specific job opening.

- No official company website or verifiable recruiter identity. Always cross-reference recruiters on LinkedIn or official HR emails.

Example 2: Fake ACH Payment Email - Berkeley Phish Tank



Fake Electronic Payment ACH Message

April 9, 2025

Many bMail account holders have recently received fake messages indicating an ACH Payment or Electronic Fund transfer.

What makes this a phishing message?

This targeted phishing scam pretending to be a UC Berkeley technician. This targeted phishing scam uses urgency and fear to cause the recipients to act, threatening loss of service (email). The email often come from @GMail accounts and indicate a payment has been made or is pending. The malicious intent of the scammer is to get payment details so they can take those credentials and initiate a fraudulent payment, or steal the credential of the recipient with a fake login page.

The most recent frauds have had subject lines like:

- Successful Completion of Your Electronic Funds Date:04042025
- Refund Pending: $399.99 Overpayment Detected
- Payment Received – Order Processing Has Begun #658-745
- AP Payment Notification 00127520

Tips if Something Seems Off:

- Unless you regularly are in contact with vendors and [provess payments for the University, unexpected notice are a red flag. You should NEVER be asked to login with your CalNet credentials to any non UC Berkeley page.

Follow up with the sender separately

If you didn't expect it, reject it. Or follow up with the individual directly in a separate email or call/text to confirm.

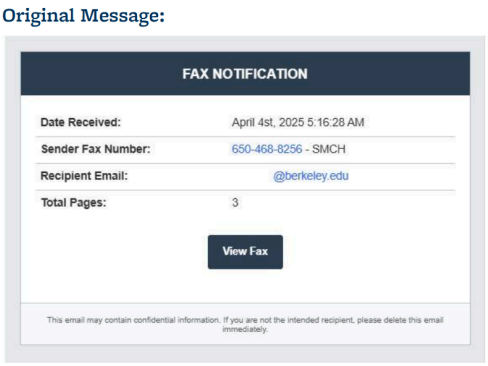
Report and/or flag it

Open the message

To the right of the 'Reply' arrow select 'More' (typically denoted with three vertical dots)

Then 'Report phishing'

For suspicious messages received by text, please take a screen shot and forward the message to phishing@berkeley.edu=For more information visit https://security.berkeley.edu/resources/phishing



Original Message:

FAX NOTIFICATION

Date Received:	April 4st, 2025 5:16:28 AM
Sender Fax Number:	650-468-8256 - SMCH
Recipient Email:	@berkeley.edu
Total Pages:	3

View Fax

This email may contain confidential information. If you are not the intended recipient, please delete this email immediately.

TOPICS

Cybersecurity Awareness

Phishing

https://security.berkeley.edu/news/fake-electronic-payment-ach-message

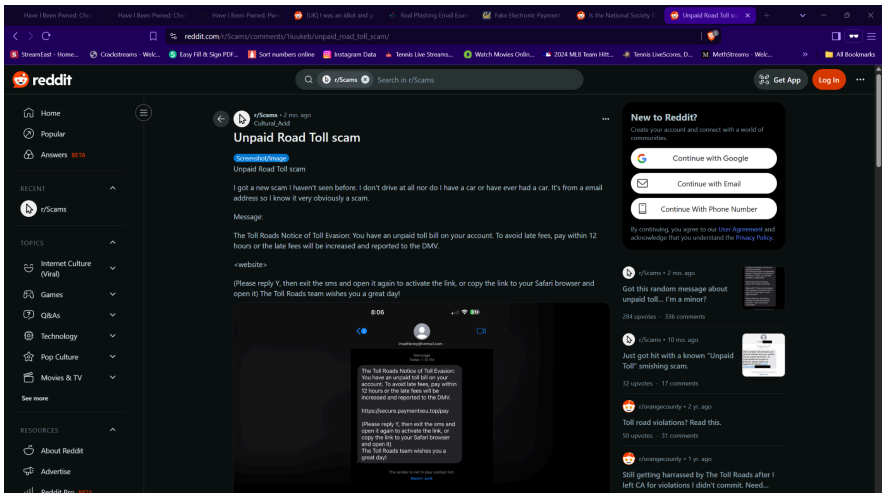
Analysis:

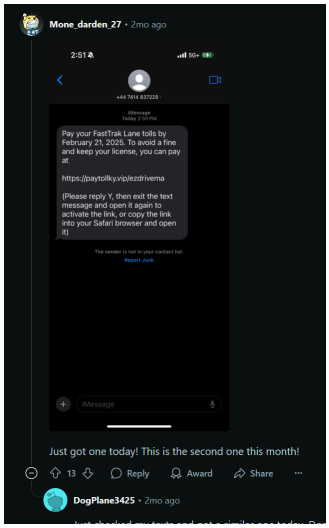
- Trust: The attacker pretends to be a UC Berkeley technician, using language typical of institutional finance departments and urgent payment notifications.
- Urgency/Fear: Subject lines like "Refund Pending: $399.99 Overpayment Detected" and "Order Processing Has Begun" trigger panic around missing money or unauthorized charges.
- Data Collection/Action: The scam links to a fake login page, attempting to steal CalNet credentials for lateral movement or financial theft.

Phishing Tells & How to Detect It:

- Subject lines use overly specific monetary values and invoice codes—classic bait.
- Fake sender address (likely not from berkeley.edu).
- Generic language with urgency, and a "View Fax" button leading to malicious links.
- Recipients should never click attachments or buttons from unexpected senders—verify through a separate trusted communication channel.

Example 3: Unpaid Road Toll SMS Scam - r/Scams





https://www.reddit.com/r/Scams/comments/1iuukeb/unpaid_road_toll_scam/

Analysis:

- Trust: The more believable phishing text came from a UK-looking number (e.g. +44...), which makes it feel regional and personal. Unlike the original post's email, the text from the comment screenshot builds authenticity through formatting and specificity.
- Urgency/Fear: Phrases like “within 12 hours or the late fees will be increased and reported to the DMV” generate panic about legal or financial penalties.
- Data Collection/Action: The text directs victims to a fraudulent link resembling a DMV or payment processor, aiming to collect sensitive payment information.

Phishing Tells & How to Detect It:

- Toll authority messages should never demand instant action via text, especially with unfamiliar domains like .vip.
- The sender is not in the victim’s contacts, and legitimate organizations usually identify themselves clearly.
- Suspicious URL formats (paytollx.vip) and repeated urgent instructions are classic indicators.

Each phishing attack demonstrated real-world social engineering patterns by manipulating trust, inducing urgency, and targeting emotional response. In each case, careful attention to red flags—such as urgency wording, suspicious domains, unverifiable senders, or crypto requests—can help users identify phishing attempts before falling victim. Teaching users to slow down and verify sources before clicking or paying is a critical layer of defense.

Step 2: Phishing Training

To reinforce my understanding of phishing tactics and social engineering methods, I completed the Department of Defense’s Phishing and Social Engineering: Virtual Communication Awareness v6.0 course, as recommended in the lab prompt. The training provided a detailed walkthrough of phishing indicators, including spoofed email addresses, link manipulation, urgent messaging patterns, and impersonation strategies. It also emphasized countermeasures such as multi-factor authentication, cautious link inspection, and the importance of reporting suspicious emails.

The course was informative and well-paced, culminating in a certificate of completion issued under my name on May 4, 2025. This training helped solidify the real-world tactics that attackers use to exploit trust and urgency, which I had previously observed in the phishing examples from Step 1. A screenshot of my certificate is provided as verification:



Step 3: TryHackMe Phishing – Room Completion and Walkthrough

For this step, I completed both TryHackMe Phishing rooms to reinforce my understanding of email-based social engineering tactics and the anatomy of malicious messages. The rooms provided hands-on exposure to realistic phishing samples and emphasized detection methods aligned with security best practices.

Room #1 – Phishing Emails 1 (https://tryhackme.com/room/phishingemails1tryoe)
This room broke down phishing fundamentals across multiple layers, including:

- Spoofed sender techniques
- Tracking pixels and HTML-based payloads
- Link manipulation through deceptive anchor text and redirection
- Usage of urgency and impersonation (e.g., fake billing issues or package tracking)

For example, in the email2.txt exercise, I removed MIME headers and used base64 -d within the TryHackMe AttackBox terminal to decode the payload into a viewable PDF file, revealing embedded phishing content. For email3.eml, I opened the message in Outlook and used CyberChef (via clipboard) to defang URLs safely, reinforcing email analysis workflows.

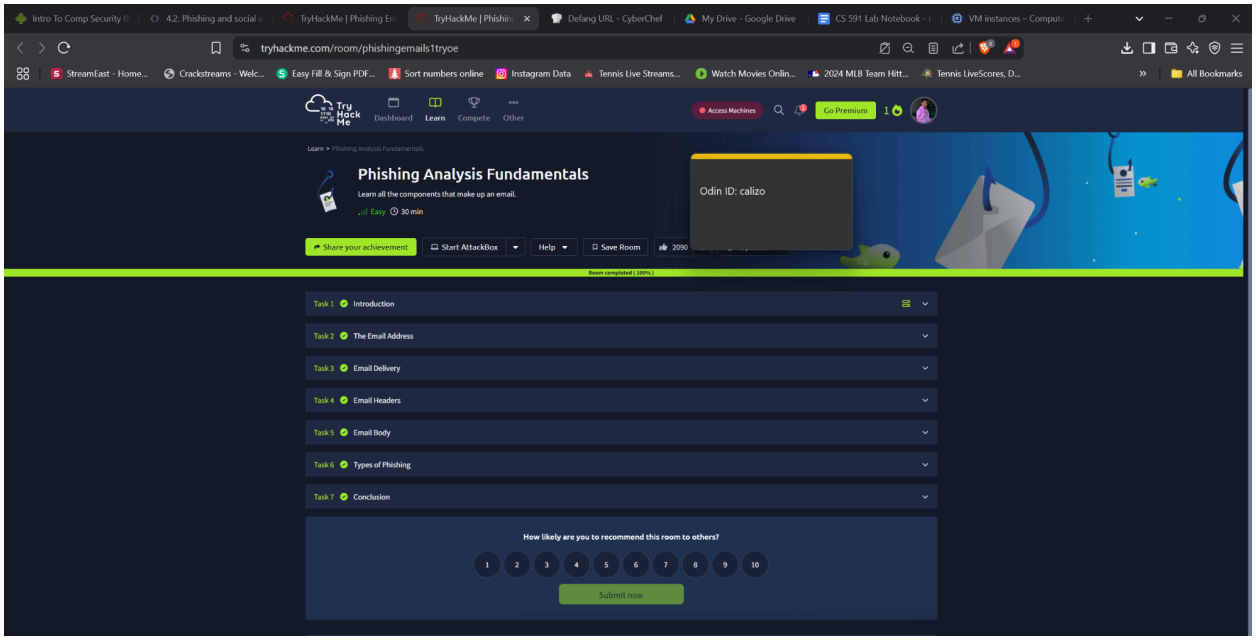
Room #2 – Phishing Emails in Action
(https://tryhackme.com/room/phishingemails2rytmuv)

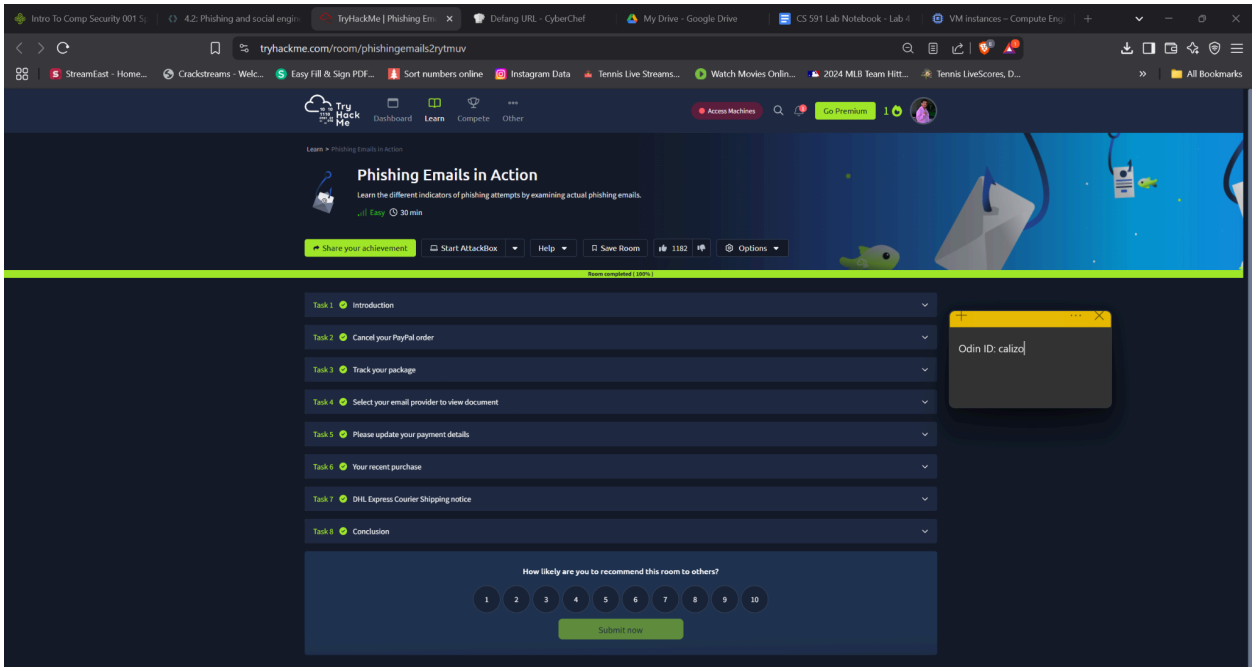
The second room expanded on advanced lures and embedded payload delivery. Key techniques explored included:

- Credential harvesting via fake OneDrive/Adobe login portals
- Malicious attachments triggering macros or disguised executables (e.g., regasms.exe in Excel files)
- Impersonation of trusted brands like PayPal, Netflix, and DHL to socially engineer the recipient

I reviewed the raw HTML of phishing messages, identified spoofed sender domains, and followed redirection chains to analyze the true nature of phishing payloads. This room highlighted how phishers carefully mimic legitimate branding while relying on urgency and curiosity to drive user interaction.

Both rooms were completed in full, as shown:


tryhackme.com/room/phishingemails1tryoe
Phishing Analysis Fundamentals
Learn all the components that make up an email.
Easy 30 min
Odin ID: calizo
Task 1 Introduction
Task 2 The Email Address
Task 3 Email Delivery
Task 4 Email Headers
Task 5 Email Body
Task 6 Types of Phishing
Task 7 Conclusion
How likely are you to recommend this room to others?
Submit now


tryhackme.com/room/phishingemails2rytmuv
Phishing Emails in Action
Learn the different indicators of phishing attempts by examining actual phishing emails.
Easy 30 min
Odin ID: calizo
Task 1 Introduction
Task 2 Cancel your PayPal order
Task 3 Track your package
Task 4 Select your email provider to view document
Task 5 Please update your payment details
Task 6 Your recent purchase
Task 7 DHL Express Courier Shipping notice
Task 8 Conclusion
How likely are you to recommend this room to others?
Submit now